المدرسة الوطنية العليا للذكاء الاصطناعي وعلوم المعطيات - تارودانت
ⵜⵉⵙⵎⵉⵔⵜ ⵜⴰⵏⴰⵎⵓⵔⵜ ⵜⴰⵙⵙⵓⵖⵍⵉⵜ ⵏ ⵓⵙⵙⵏⵙ ⴰⵔⵜⵉⴼⵉⵙⵢⴻⵍ ⴷ ⵜⵎⴰⵡⴰⵙⵉⵏ ⵏ ⵜⵣⵔⴼⵜ - ⵜⴰⵔⵓⴷⴰⵏⵜ
ÉCOLE NATIONALE SUPÉRIEURE DE L'INTELLIGENCE ARTIFICIELLE ET SCIENCES DES DONNÉES – TAROUDANT

M352 : Sécurité de la virtualisation et du Cloud Computing

Filière : Sécurité IT et Confiance Numérique

CH3 – Sécurité des environnements virtualisés

Hyperviseurs, VM, isolation, réseau virtuel et hardening

Prof. AGALIT Mohamed Amine

Objectifs pédagogiques de C3

À la fin, l'étudiant doit savoir sécuriser un environnement virtualisé de base

Comprendre

Pile de virtualisation : matériel, hyperviseur, VM, images, snapshots, réseau virtuel.

Identifier

Composants critiques : hyperviseur, console admin, vSwitch, stockage, images, comptes privilégiés.

Appliquer

Mesures de hardening : patch, accès admin, isolation, moindre privilège, segmentation, logs.

Analyser

Un scénario de risque et proposer des contre-mesures cohérentes.

Préparer le TP1

Mettre en place des VM et réseaux virtuels en comprenant les choix de sécurité.

Préparer C4

Comprendre les bases avant d'étudier VM escape, hyperjacking et vulnérabilités.

Déroulement de la séance

- Rappel CH2 + enjeu CH3
- Pile de virtualisation et composants critiques
- Activité 1 : localiser les contrôles
- Isolation VM, ressources, stockage, réseau virtuel
- Activité 2 : hardening d’une VM
- Hardening hyperviseur, accès admin, logs, sauvegardes
- Activité 3 : VM vs conteneur
- Quiz final

De l’architecture Cloud à la couche de virtualisation

CH2 parlait architecture ; CH3 sécurise la couche qui exécute les VM

Application

OS invité

VM

Hyperviseur

Matériel



Message clé

En IaaS, il faut savoir raisonner à la fois sur la VM, son OS, son réseau virtuel, ses images et la plateforme qui les héberge.

Les 5 objectifs de sécurité d’un environnement virtualisé

On sécurise un système virtualisé en maîtrisant cinq dimensions



Isoler

éviter qu’une VM influence une autre



Contrôler

limiter les privilèges et accès admin



Durcir

réduire services, ports, paramètres faibles



Observer

journaliser et détecter les anomalies



Restaurer

snapshots, backups et reprise maîtrisée

Architecture type d’un environnement virtualisé

Une plateforme virtualisée contient trois zones à protéger

Plan de gestion

Console d’administration, API, rôles, comptes, journaux.

Hyperviseur

Allocation CPU/RAM, scheduling, isolation, accès périphériques.

Plan de données

Flux réseau, disques virtuels, snapshots, images, VM.



L’hyperviseur : racine de confiance technique

S’il est compromis, toutes les VM peuvent être en danger

Rôle

Créer et exécuter les VM
Allouer CPU/RAM
Gérer les disques virtuels
Présenter le réseau virtuel
Assurer l’isolation

Risques

Mauvaise configuration
Correctifs absents
Accès admin trop large
Interfaces de gestion exposées
Extensions/modules non nécessaires

Mesures

Patch management
Accès admin restreint
MFA si possible
Journalisation
Désactivation services inutiles
Sauvegarde configuration

Activité 1 — Localiser les contrôles de sécurité

Consignes

Sur un schéma VM + hyperviseur + réseau, placez au moins 6 contrôles.
Classez-les : accès, réseau, stockage, logs, sauvegarde.
Indiquez le contrôle le plus critique selon vous.

Méthode et autocorrection

1. Repérez d’abord le plan de gestion.
2. Ajoutez un contrôle pour l’hyperviseur.
3. Protégez réseau, stockage et journaux.

Cycle de vie d’une VM : la sécurité commence avant le démarrage

Une VM n’est pas seulement un système lancé : c’est un objet administré



- Une image compromise propage la vulnérabilité à toutes les VM créées.
- Un snapshot contient souvent données, clés, sessions ou configurations sensibles.
- Un clone oublié devient une machine fantôme non maintenue.

Isolation des ressources : CPU, RAM, stockage

L'isolation est un objectif de sécurité et de stabilité

CPU

Éviter la saturation par une VM gourmande. Utiliser quotas, réservations, priorités selon la plateforme.

RAM

Limiter l'impact d'une VM mal configurée. Surveiller ballooning, swap excessif et pression mémoire.

Stockage

Contrôler les disques virtuels, snapshots, datastores, chiffrement et permissions.

Une mauvaise gestion des ressources peut devenir un problème de disponibilité et de sécurité.

Stockage virtuel et snapshots : bénéfices et risques

Ce qui facilite l'administration peut aussi faciliter la fuite

Bénéfices

Restauration rapide
Tests sans risque immédiat
Clonage rapide
Rollback après mise à jour

Risques

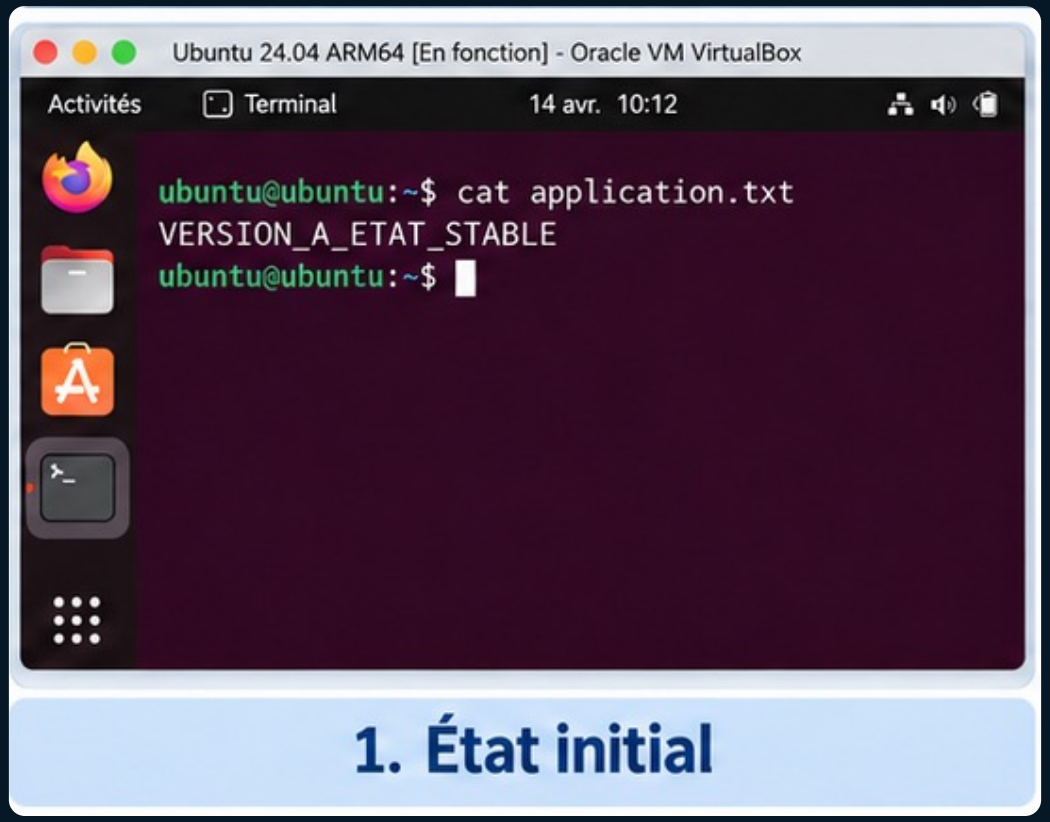
Données sensibles copiées
Snapshots oubliés
Croissance stockage
Exposition d'images
Retour arrière qui annule un patch

Bonnes pratiques

Chiffrer si possible
Limiter droits
Nommer et dater
Durée de rétention
Tester la restauration
Supprimer snapshots inutiles

Démonstration 1 — Préparer le point de retour

Étapes 1 et 2 : état stable puis création du snapshot

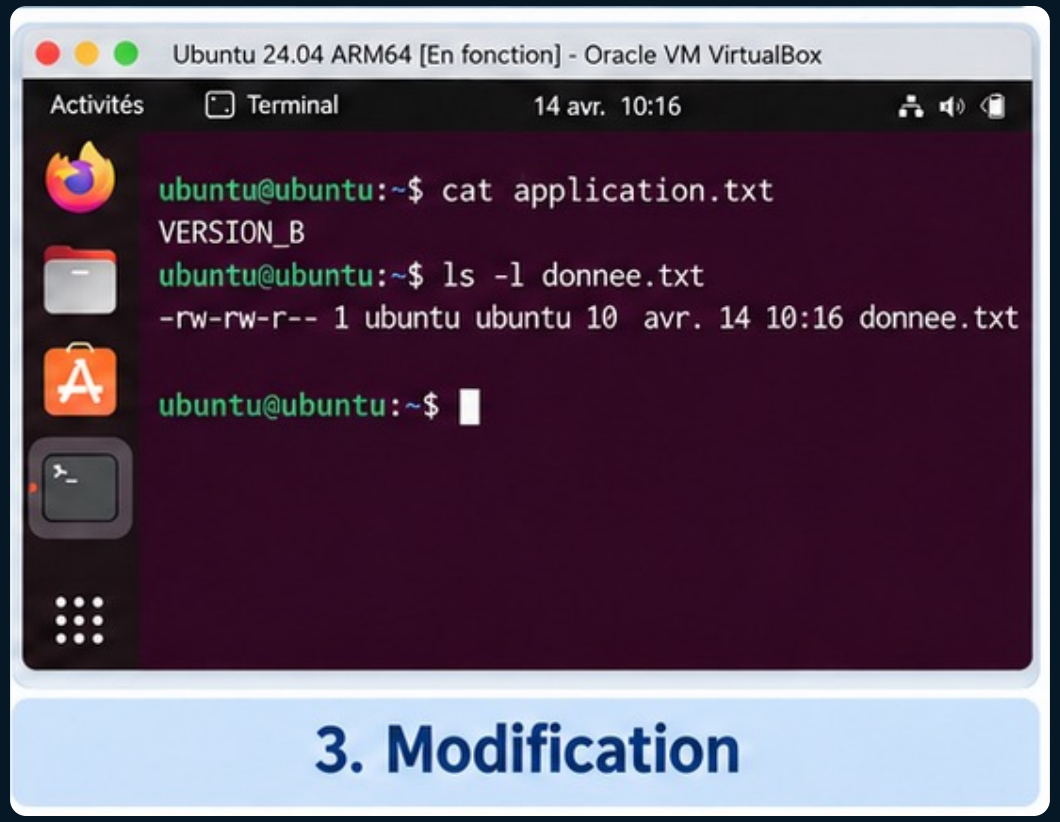




Le snapshot mémorise l'état de la VM avant une modification risquée.

Démonstration 1 — Modifier puis restaurer

Étapes 3 et 4 : changement de l'état puis retour au snapshot

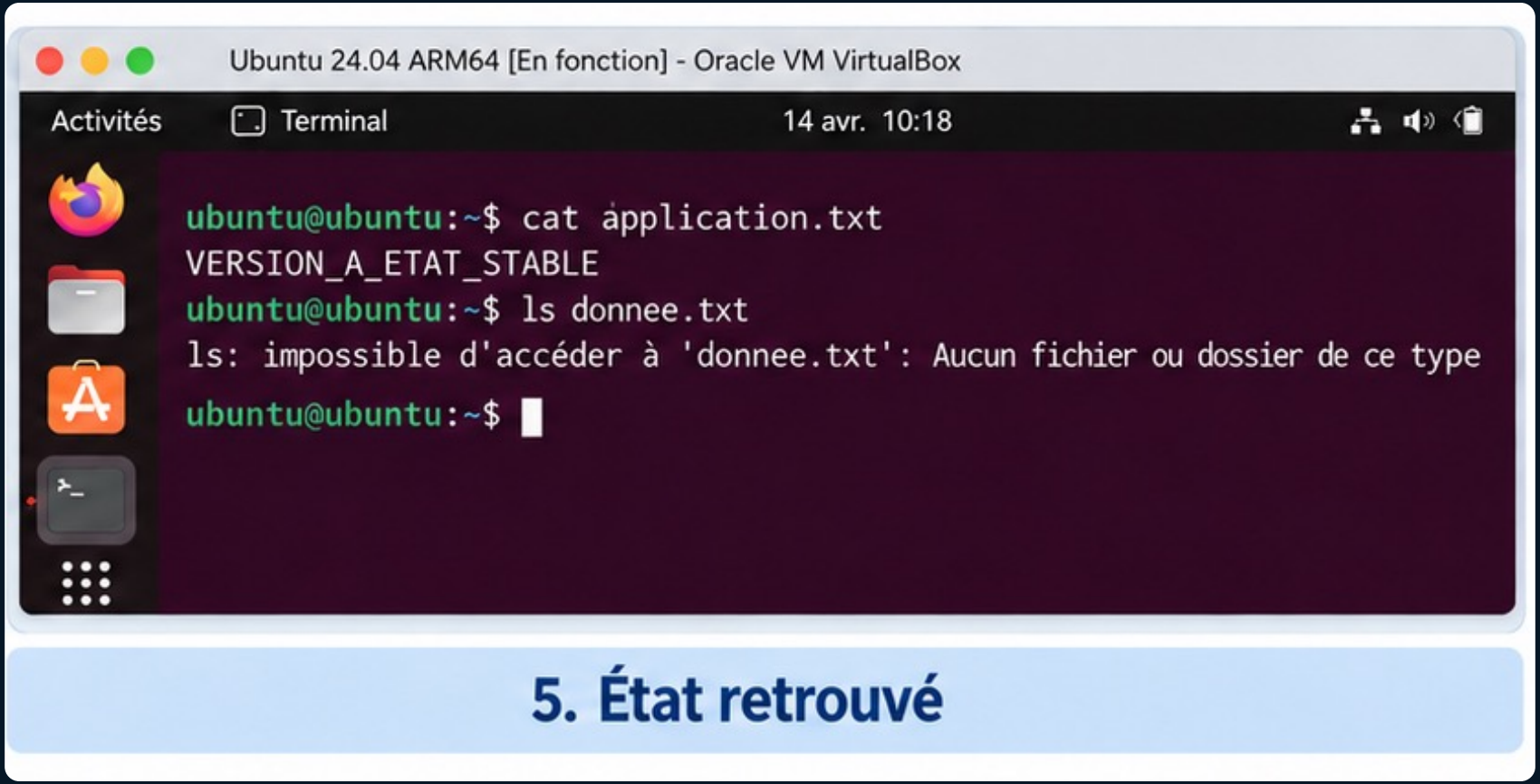




La restauration annule les modifications intervenues après le snapshot.

Démonstration 1 — Vérifier la restauration

Étape 5 : contrôle de l'état retrouvé



VERSION_A réapparaît et le fichier ajouté après le snapshot disparaît.

Réseau virtuel : vSwitch, interfaces et segments

Le réseau virtuel doit être conçu comme un vrai réseau

Composants

vSwitch / bridge
Interfaces virtuelles
NAT / Host-only / Internal
VLAN / segments
Règles firewall

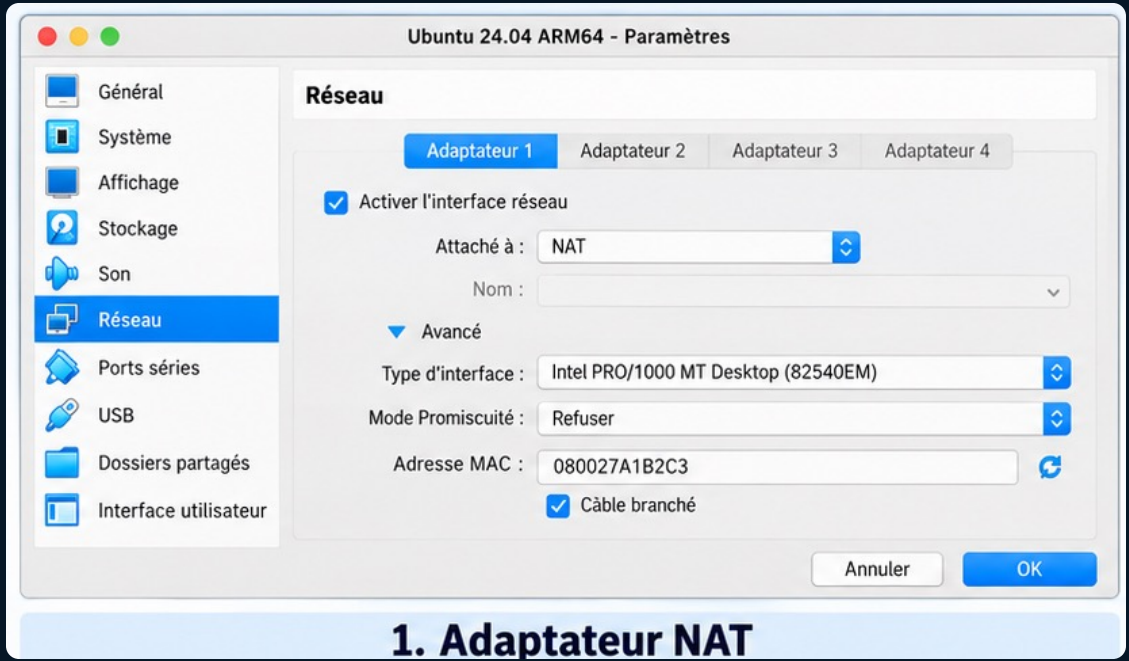
Questions sécurité

Qui peut parler avec qui ?
Quelle VM a accès Internet ?
Quel trafic est filtré ?
Où capturer les logs ?
Comment administrer sans exposer ?

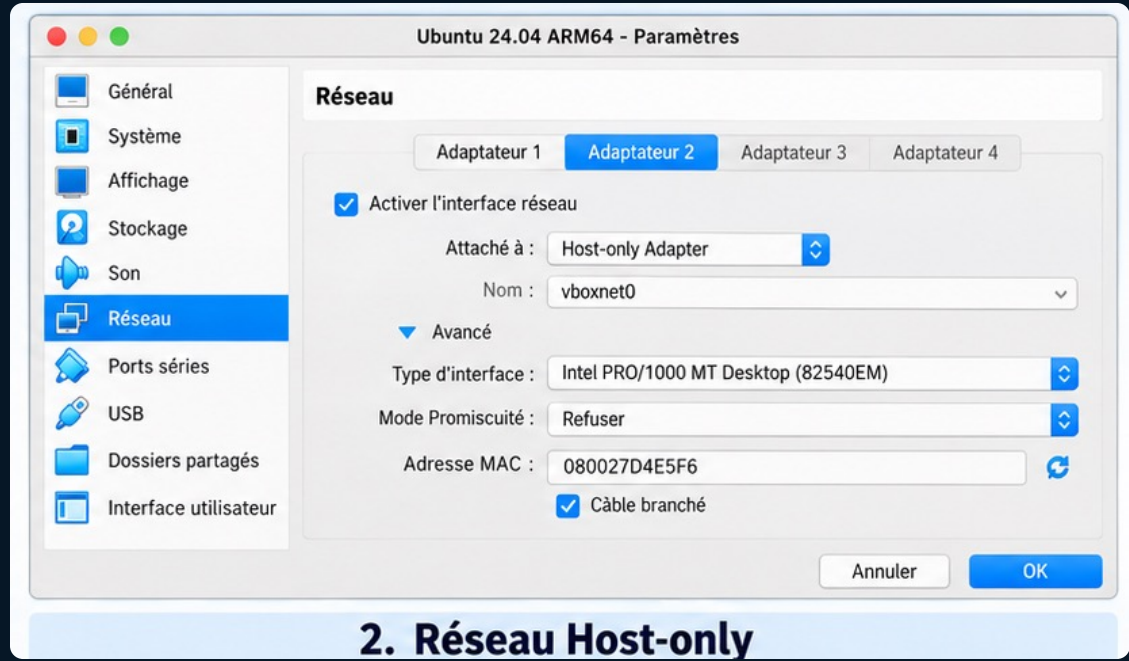


Démonstration 2 — Configurer les deux réseaux

NAT pour Internet, Host-only pour la communication privée avec le Mac



1. Adaptateur NAT

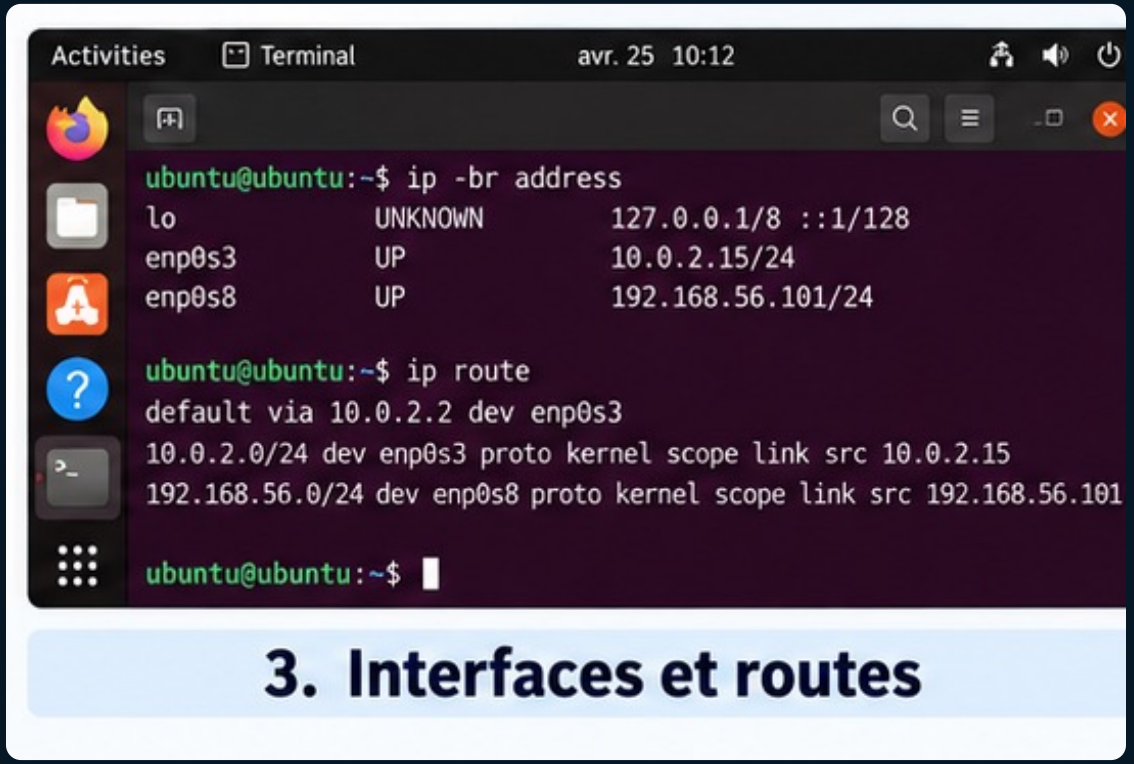


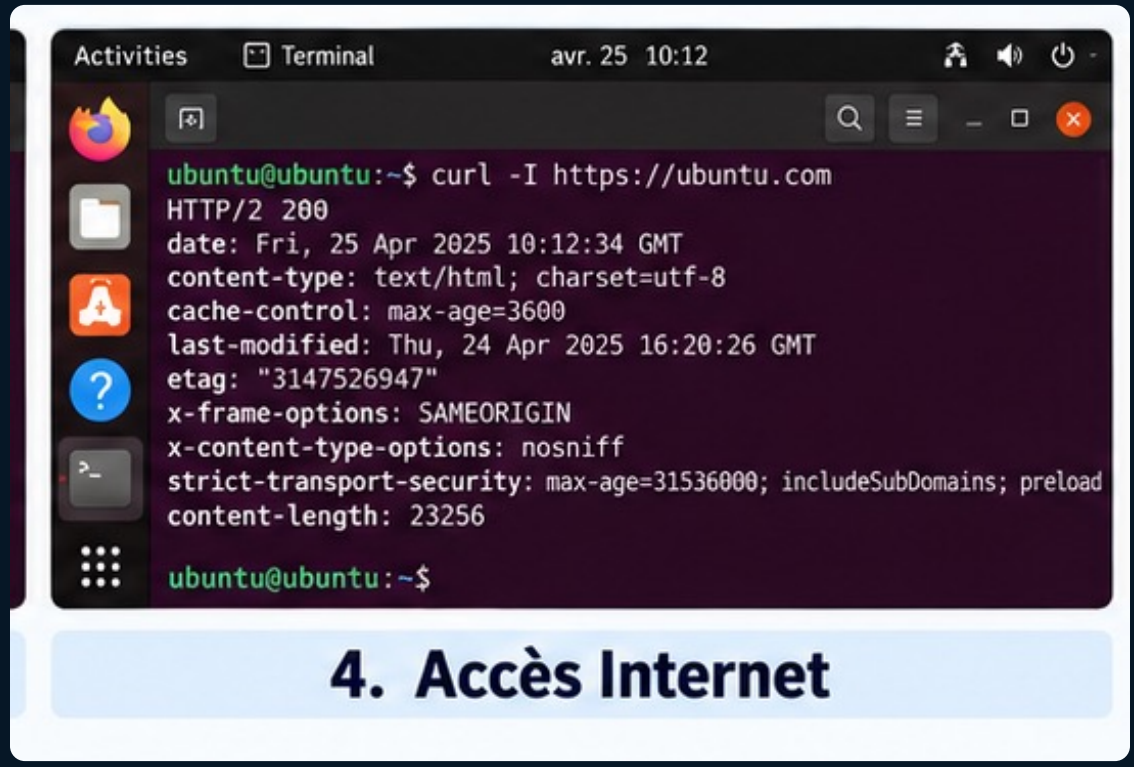
2. Réseau Host-only

Chaque adaptateur répond à un besoin distinct de communication.

Démonstration 2 — Identifier les interfaces

Adresses IP, route par défaut et test de sortie Internet

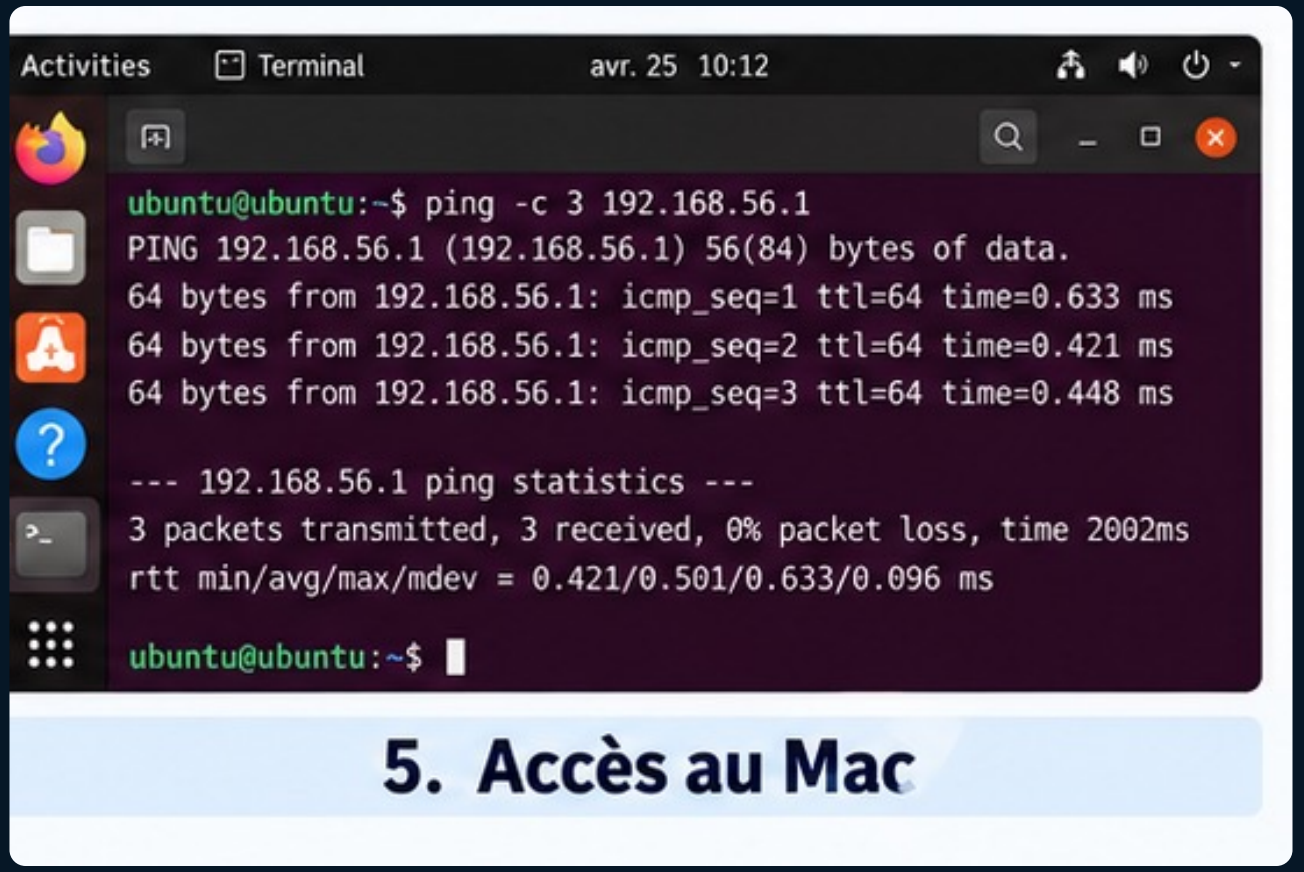




La route par défaut passe par NAT, tandis que Host-only reste un réseau local privé.

Démonstration 2 — Tester le réseau Host-only

Communication entre la VM Ubuntu et l'interface privée du Mac



Le test vers 192.168.56.1 valide le lien privé entre l'hôte et la VM.

Accès d’administration : la cible la plus sensible

La console permet parfois de créer, arrêter, cloner ou supprimer des VM

Menaces

Compte admin partagé
Mot de passe faible
Console accessible depuis tout le réseau
Absence de logs
Clés/API exposées

Contrôles

Comptes nominatifs
Moindre privilège
MFA si disponible
Segmentation réseau admin
Journalisation et alertes
Sauvegarde configuration

Phrase à retenir

Sécuriser les VM sans sécuriser la console d’administration revient à fermer les portes tout en laissant le trousseau de clés dehors.

Hardening de l’hyperviseur : base de sécurité

Réduire la surface d’attaque de la plateforme

- Installer les correctifs et suivre les avis de sécurité du fournisseur.
- Désactiver services, interfaces et modules non nécessaires.
- Restreindre l’accès à l’interface d’administration.
- Utiliser des comptes nominatifs et limiter les droits.
- Activer journaux, alertes et synchronisation NTP.
- Sauvegarder la configuration de la plateforme.
- Séparer si possible réseau de gestion, réseau VM et stockage.

Attention

En Cloud public, le client ne durcit pas l’hyperviseur fournisseur, mais il doit comprendre cette responsabilité et vérifier les garanties contractuelles, logs et options de sécurité disponibles.

Hardening d’une VM : première checklist

Une VM doit être traitée comme un serveur réel, pas comme un simple fichier

Système

Mises à jour
Services inutiles arrêtés
Pare-feu local
Comptes contrôlés
SSH/RDP protégés

Configuration

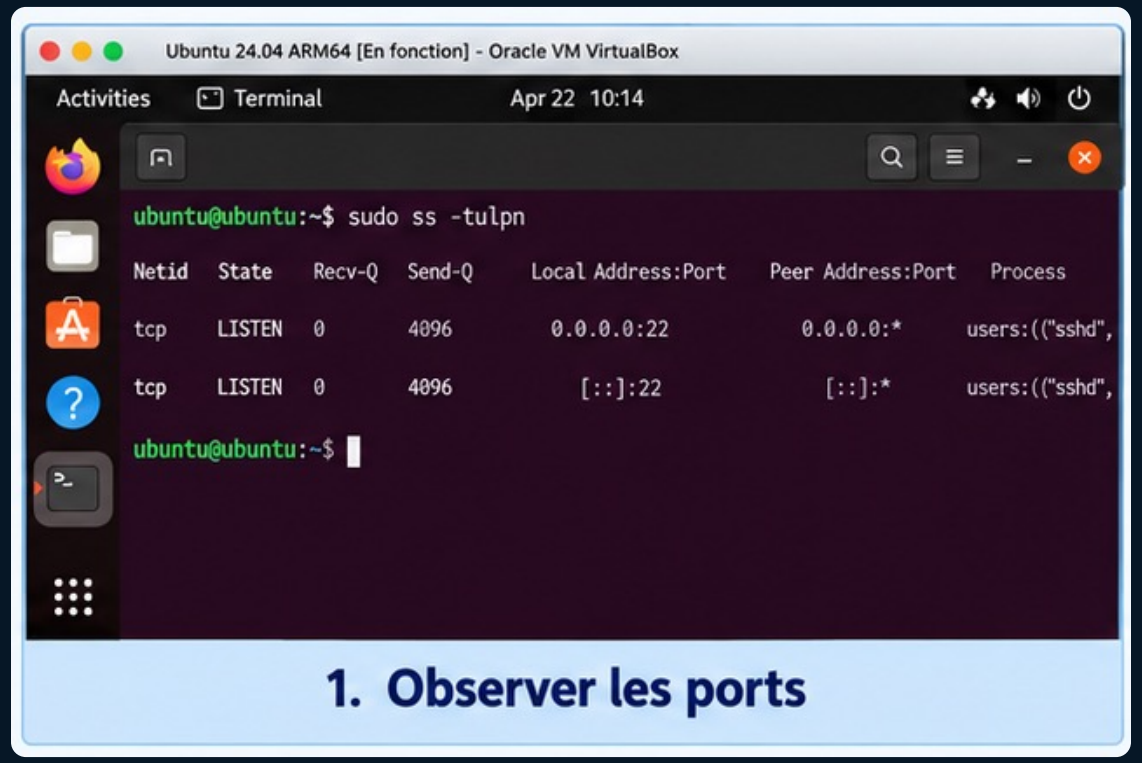
Hostname clair
Adresse/flux justifiés
Permissions minimales
Logs actifs
Horloge synchronisée

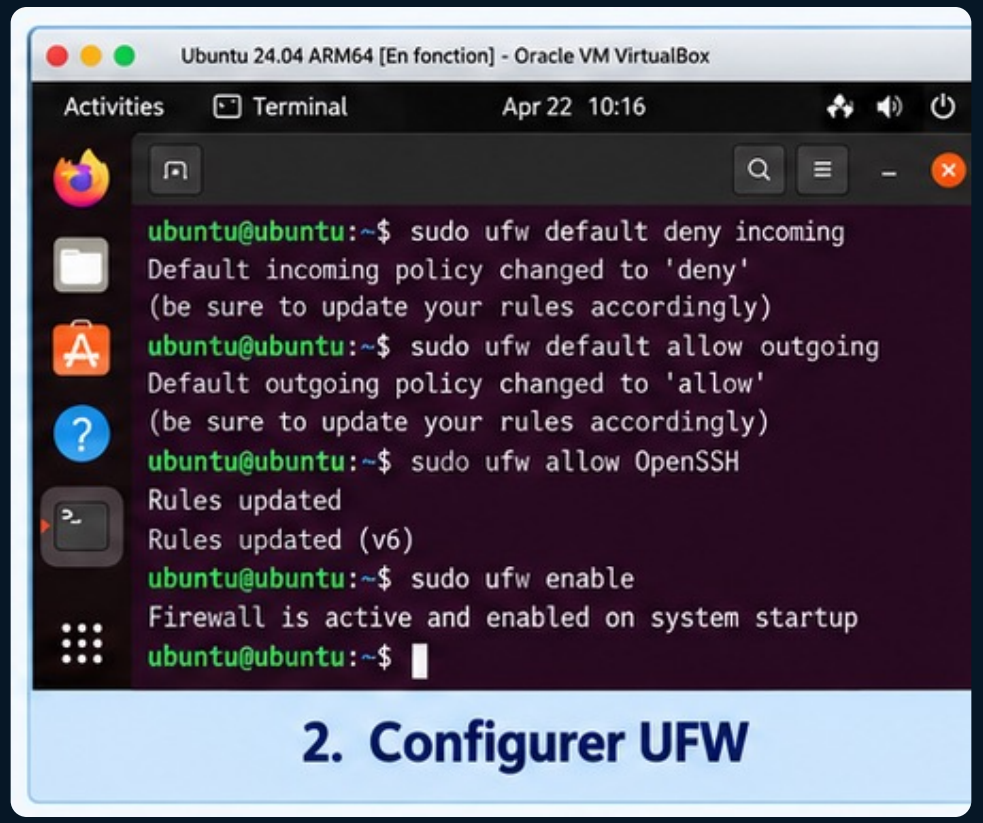
Exploitation

Sauvegardes
Snapshots maîtrisés
Inventaire
Supervision
Revue régulière

Démonstration 3 — Observer puis filtrer

Inventaire des ports et activation d’une politique UFW minimale

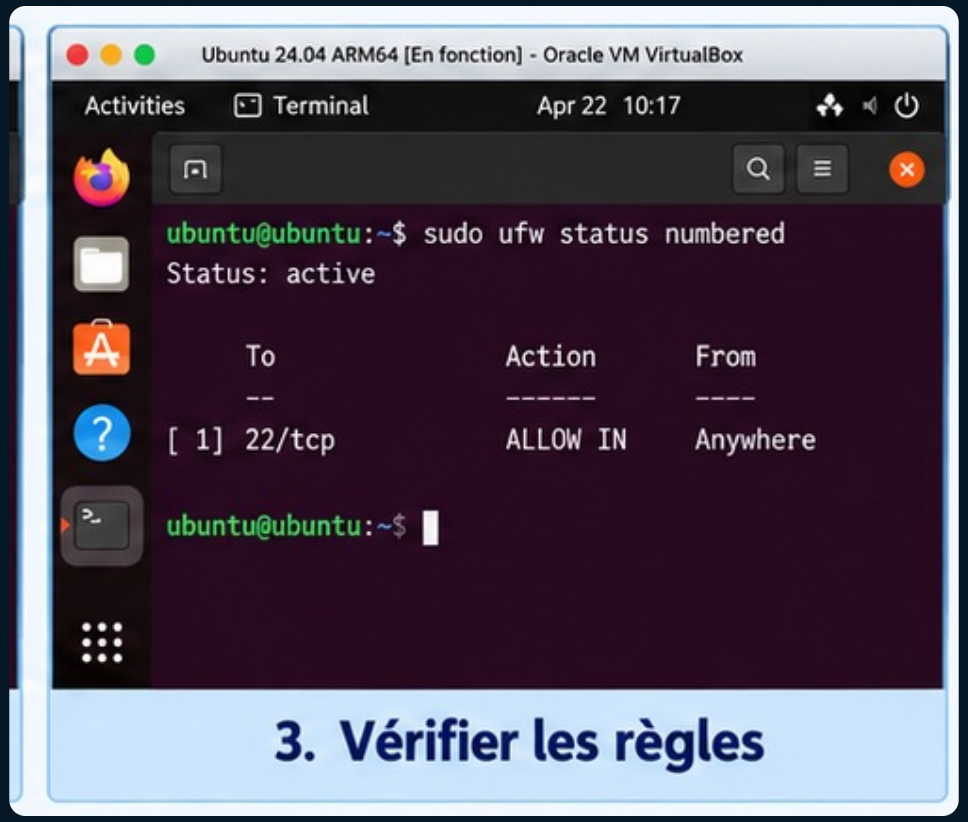




Le durcissement commence par l’observation avant l’application des règles.

Démonstration 3 — Vérifier UFW et SSH

Contrôle de la règle active et de la configuration effective de SSH

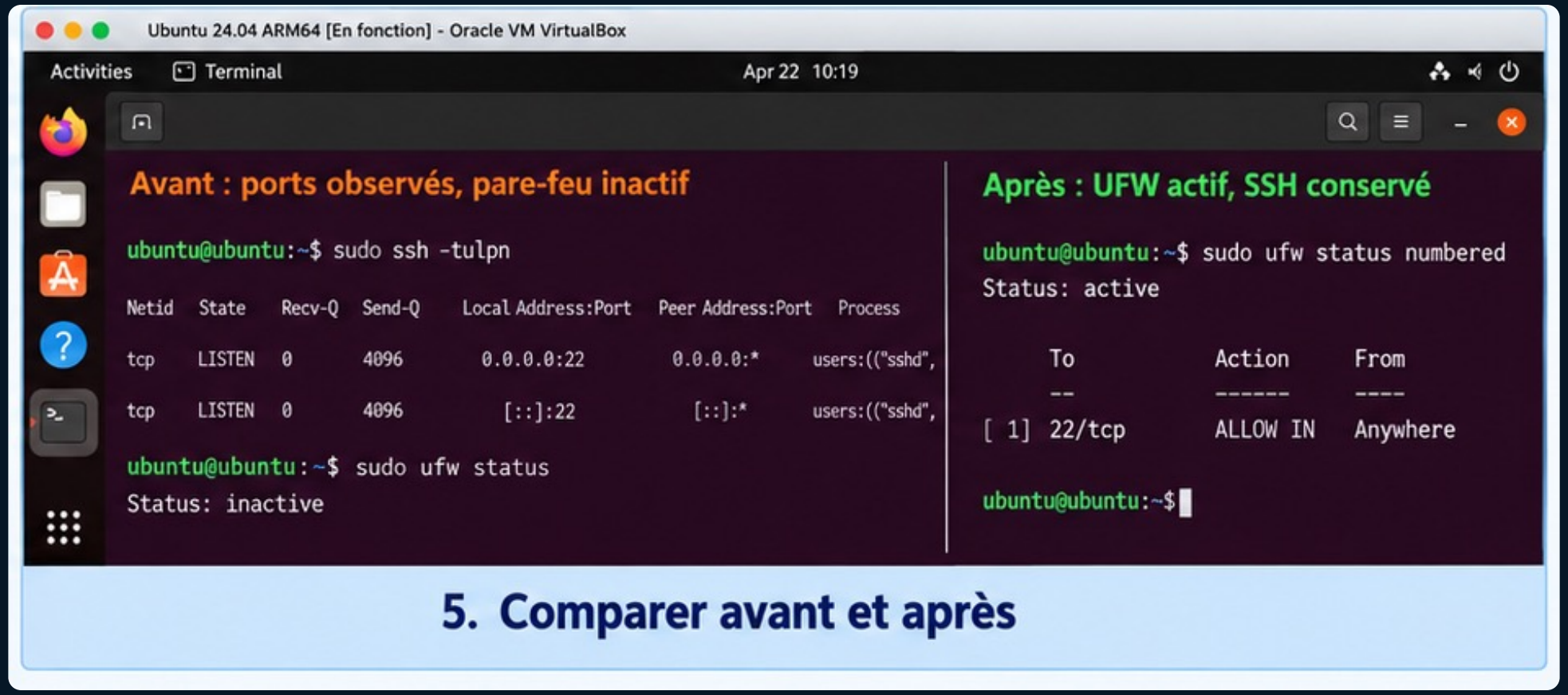




Une mesure de sécurité doit toujours produire une preuve vérifiable.

Démonstration 3 — Comparer avant et après

Synthèse des changements et des preuves obtenues



Après le durcissement, UFW filtre les entrées tout en conservant le service SSH nécessaire.

Activité 2 — Durcir une VM mal configurée

Consignes

Situation : une VM Linux a SSH ouvert, mot de passe faible, firewall désactivé, services inutiles.
Proposez 5 actions de correction prioritaires.
Justifiez l'ordre des actions.

Correction

1-Classez les actions selon le danger immédiat.
2- Commencez par sécuriser l'accès SSH, puis le pare-feu et les mises à jour.
3-Terminez par les services inutiles, les logs et la vérification.

Mises à jour et maintenance : ne pas casser la production

Sécuriser implique de corriger sans perdre la disponibilité

Avant

Inventaire des VM
Priorité selon exposition
Snapshot ou backup
Fenêtre de maintenance
Plan de retour arrière

Pendant

Appliquer patches
Vérifier services
Surveiller logs
Tester connectivité
Documenter incidents

Après

Supprimer snapshots inutiles
Valider sécurité
Mettre à jour CMDB/inventaire
Communiquer résultat

Journalisation et supervision

Sans logs, il est difficile de détecter et d'expliquer un incident

Logs plateforme

Connexions admin
Création/suppression VM
Modification réseau
Accès datastore
Erreurs hyperviseur

Logs VM

Auth SSH/RDP
Services exposés
Pare-feu local
Mises à jour
Erreurs système

Alertes utiles

Connexion admin inhabituelle
VM créée hors procédure
Snapshot massif
Stockage presque plein
Flux réseau anormal

Ces traces seront indispensables pour audit, détection et réponse à incident.

Sauvegarde, snapshot et restauration : ne pas confondre

Un snapshot n’est pas toujours une vraie sauvegarde

Objet	But	Limite
Snapshot	Retour rapide à un état précédent	Peut dépendre du même stockage et ne remplace pas une sauvegarde
Backup	Restaurer après perte, corruption ou ransomware	Doit être testé, protégé et parfois hors ligne
Clone	Créer une copie exploitable	Risque de VM fantôme ou de données dupliquées

Règle pratique

Ce qui n’a jamais été testé en restauration n’est pas encore une vraie stratégie de reprise.

Mauvaises configurations fréquentes

La plupart des incidents naissent d’un détail simple oublié

- VM de test laissée allumée avec mots de passe faibles.
- Interface d’administration accessible depuis un réseau trop large.
- Snapshots contenant données sensibles et jamais supprimés.
- Réseaux virtuels mélangés : production, test, administration.
- Images de VM non mises à jour puis réutilisées.
- Absence d’inventaire : personne ne sait quelles VM existent réellement.
- Pas de journalisation ou logs conservés trop peu longtemps.



Ouverture moderne : VM et conteneurs

À ne pas confondre, mais les questions d’isolation se ressemblent

VM

Chaque VM possède un OS invité complet. Isolation forte via hyperviseur. Plus lourde, mais séparation nette.

Conteneur

Partage le noyau de l’hôte. Plus léger, démarrage rapide. Isolation différente, dépendante du runtime et du kernel.

Point sécurité

toute mutualisation demande isolation, contrôle, durcissement et surveillance.

Activité 3 — VM ou conteneur ?

Consignes

Comparez VM et conteneur sur 3 critères : isolation, ressources, surface d’attaque.
Expliquez pourquoi un conteneur privilégié peut être dangereux.
Donnez une mesure de durcissement pour chaque cas.

Méthode et autocorrection

VM : noyau propre et isolation par hyperviseur.
Conteneur : noyau partagé avec l’hôte.
Un conteneur privilégié augmente l’impact d’une compromission.

Mini-cas : ENSIA-Tech virtualise ses services

Appliquer le raisonnement CH3 à un cas réaliste

Contexte

5 serveurs physiques migrés vers 6 VM : Web, DB, fichiers, annuaire, supervision, test. Un seul hôte VirtualBox/Proxmox en laboratoire.

Questions

Quelles VM isoler ?
Quel réseau pour l'administration ?
Quels snapshots garder ?
Quels logs activer ?
Quels services désactiver ?

Sortie attendue

Une mini-politique de hardening : réseaux séparés, accès admin limité, comptes nominaux, pare-feu, logs, sauvegarde et suppression des snapshots inutiles.

Checklist ingénieur pour sécuriser une plateforme virtualisée

- ✓ Inventaire des hôtes, VM, images et snapshots
- ✓ Accès admin restreint et tracé
- ✓ Réseaux de gestion / VM / stockage séparés si possible
- ✓ Hyperviseur et VM à jour
- ✓ Services inutiles désactivés
- ✓ Pare-feu et segmentation appliqués
- ✓ Logs activés et centralisés si possible
- ✓ Sauvegardes testées
- ✓ Snapshots nommés, datés, avec rétention limitée
- ✓ Documentation de configuration

Activité 4 — Quiz final

Consignes

Répondez rapidement :
1) Pourquoi protéger les snapshots ?
2) Quelle est la différence entre réseau Host-only et NAT en TP ?
3) Citez 3 mesures de hardening hyperviseur.
4) Pourquoi une console admin exposée est-elle critique ?
5) Un snapshot est-il une sauvegarde ? Justifiez.

Correction rapide

1. Ils peuvent contenir données et secrets.
2. NAT : sortie Internet ; Host-only : réseau privé avec l'hôte.
3. Correctifs, accès restreint, services minimaux.
4. Elle donne le contrôle des VM.
5. Non, elle dépend souvent du même stockage.

Synthèse CH3 : méthode de sécurisation d’une plateforme virtualisée

La virtualisation améliore l’efficacité mais concentre certains risques

Hyperviseur

composant critique

VM

serveur réel à durcir

Réseau virtuel

segmentation obligatoire

Snapshots/images

actifs sensibles

Admin plane

accès à protéger

Logs/backups

preuves et résilience

Prochaine étape : TP1 - création et sécurisation d’un environnement virtualisé.